ITA CHALLENGE SPRINT · SEMANA 5 · DOSSIÊ FINAL E PROPOSTA DE VALOR

GerencIA — governança de IA que a empresa pode provar.

O dossiê reúne as cinco semanas: do problema ao protótipo que roda, do papel da IA aos resultados dos testes, do impacto à viabilidade e aos próximos passos.

Desafio 2 · Stark Bank · base oficial: 650 eventos · 14 regras · 15/15 do gabarito · 98,8% de concordância · dados fictícios

---

A proposta de valor em uma frase: a GerencIA transforma "achamos que estamos seguros no uso de IA" em "conseguimos provar onde não estamos" — rastreando a **informação** (não o clique), reaplicando a política com **IA auditável** e mantendo o conteúdo **dentro do perímetro**.

01 · Problema e recorte

A decisão que precisa melhorar

A empresa já registra o uso de IA, mas **não confia no registro**: a classificação é confiada, não verificada, e não há linhagem ligando uma informação às ferramentas e pessoas por onde passou. O recorte do Sprint: **rastrear a informação**, reaplicar a política de risco com cadeia de evidência e auditar a rotulagem — sobre a base oficial do desafio, mais a captura ao vivo na borda. Fora do escopo: bloqueio ativo, substituir o DLP existente, e detecção de paráfrase.

02 · Evidências

O problema está na própria base

7 / 10
indicadores declarados divergem do apurado

6,8% → 16,6%
eventos críticos: subnotificação de ~2,4×

6
achados de auditoria (A-01…A-06), verificáveis célula a célula

Entre os achados: 38 eventos cuja regra citada engana o auditor; 18 em que a obrigação de LGPD some do registro; 6 das 14 regras que nunca disparam; 47 alertas “tratados” sem data (SLA não apurável).

---

03 · Solução e protótipo

Não é mockup — já roda

O protótipo V1 lê a planilha, aplica as 14 regras, audita, monta o painel e recebe capturas ao vivo das estações, com um comando. Reproduz **15/15** dos casos do gabarito e concorda com o nível de risco da base em **98,8%**; os dois motores (Python e navegador) batem em tudo.

Rastrear
Busca reversa: da informação para ferramentas, pessoas e vezes.

Motor R01–R14
Risco por precedência, com cadeia de evidência por evento.

Auditoria + Validação
Indicadores recalculados, os 6 achados, e 15/15.

---

04 · Papel da IA

Três níveis, em cascata — e auditável

Nível 0 · borda	**Detectores determinísticos** — CPF/CNPJ (dígito), cartão (Luhn), credenciais + fingerprint. Instantâneo, explicável.
Nível 1 · on-premise	**Qwen3 (llamafile), no servidor** — classifica tipo + sensibilidade do texto livre em ~0,3 s. **O conteúdo não sai da máquina.**
Nível 2 · nuvem	**Claude (claude-opus-5)** — só o resíduo de baixa confiança; devolve aprendizado aos níveis locais.

A IA é o **núcleo** (classifica, decide, rastreia) e é **aceitável em Compliance** porque decide por regras explícitas com evidência — cada captura grava **como foi classificada** (`classificado_por`).

05 · Arquitetura e dados

On-premise, do edge ao painel

Borda (extensão · agente · proxy) → Coletor (identidade no SO) →
Núcleo (motor + Qwen3 ⇄ nuvem) → Base unificada → Painel

Dados: legado (650 eventos, 160 alertas, 8 ferramentas, 20 tipos, 72 usuários, 14 regras; fictícios) + presente (capturas ao vivo, identidade resolvida no SO, origem marcada). Núcleo em **VLAN sem saída**; só a **DMZ** de notificação fala com fora. A solução **mede a qualidade** da rotulagem — é assim que acha os 6 achados.

06 · Resultados dos testes

Validado em estação real

Além do gabarito (15/15) e da paridade dos motores, a solução foi exercitada **numa estação Windows real** (Parallels), com o Mac como servidor:

Teste	Resultado
Agente instalado como serviço do Windows	**Running / Automatic, sobe no boot**
Extensão capturando conteúdo (prompt + resposta)	**OK, com busca única (par_id)**
Identidade do usuário logado	**resolvida pelo host nativo (multiusuário), não falsificável**
Classificação Nível 0 (CPF em prompt real)	**"Dado pessoal (CPF)" / Crítica, na hora**
Classificação Nível 1 (Qwen3 local)	**tipo + sensibilidade em ~0,3 s, on-premise**

Os testes também expuseram e **corrigiram** atritos reais de campo: falso-positivo de CDN (resolvido com cache de DNS como autoridade), flood do agente (dedup por uso, 8 h), identidade por ID fixo da extensão, e as frições de implantação no Windows (Python, execution policy, ACL pt-BR).

07 · Impacto

O que muda para o negócio

Confiança

Governança que fecha auditoria

Indicadores apurados com evidência no lugar de números que erram 2,4×; meta de zerar as 7 divergências.

LGPD

Obrigação no registro

Detecta dado pessoal em IA pública e marca a resposta de privacidade — o A-02 mostra onde isso some hoje.

Privacidade

Conteúdo no perímetro

Nível 0 e 1 classificam on-premise; a nuvem só vê o resíduo ambíguo.

Linhagem

Busca reversa da informação

Partir de um documento sensível e ver toda a sua trajetória — a pergunta norteadora do desafio.

---

08 · Viabilidade

Implementável de verdade

- **Sem dependência de nuvem** no caminho comum: o núcleo e o Qwen3 (Nível 1) rodam no servidor da empresa; Python puro, sem `pip install` para o núcleo.
- **Implantação em massa** pronta: instalador do agente como serviço + **GPO/Intune** (silencioso, detecção, desinstalação), extensão com ID fixo e host de identidade por usuário.
- **Custo baixo:** a maioria é resolvida nos Níveis 0 e 1 (custo zero de inferência externa); o LLM na nuvem é exceção.
- **Testado no ambiente-alvo** (Windows real), não só em laboratório.

---

09 · Adoção, riscos e próximos passos

Do piloto à escala

Adoção

Piloto → onda

Começar por uma área (ex.: Financeiro), com aviso de monitoramento; expandir por GPO/Intune após validar.

Riscos

Limites honestos

Senha do serviço barra usuário/admin casual, não o admin determinado (exige MDM/EDR); MITM é opt-in; modelo local pequeno (há limiar + Nível 2).

Próximos passos

Fase 2

Assinar a extensão, fingerprint em LSH para escala, ligar o Nível 2, fechar a paridade de hash e o fluxo de LGPD.

Critério da Semana 5

Viabilidade e potencial de negócio

01

Viabilidade de implementação

On-premise, Python puro no núcleo, deploy por GPO/Intune, testado em estação Windows real.

02

Impacto e business case

Governança auditável (zerar 7 divergências), LGPD no registro, privacidade por desenho, linhagem da informação.

03

Adoção e próximos passos

Piloto por área → onda via GPO/Intune; riscos nomeados; fase 2 definida.

04

Material final vende a ideia

Dossiê que liga problema → evidência → protótipo que roda → resultados reais → viabilidade, com números verificáveis.